

What is the MITRE Framework (ATT&CK)?

MITRE ATT&CK stands for:

Adversarial Tactics, Techniques, and Common Knowledge

It's a **global knowledge base** created by the **MITRE Corporation (USA)** that documents **how real-world attackers behave** — the steps, tools, and tricks they use to hack systems.

Think of it as a **big library of hacker behavior**, organized in a structured way so that cybersecurity teams can:

- Understand **how attacks work**
- Detect them early
- Defend or respond effectively

The Structure of MITRE ATT&CK

It's divided into three main layers:

1. **Tactics (What attackers want to achieve)**
2. **Techniques (How they do it)**
3. **Sub-techniques (More specific "how")**

1 Tactics — the attacker's goals

These are the **phases or objectives** in an attack (like stages of a crime).

There are 14 main tactics in the Enterprise ATT&CK matrix.

No.	Tactic	Description	Example
1	Reconnaissance	Gathering information before the attack	Finding employee emails from LinkedIn
2	Resource Development	Preparing tools or accounts	Registering a fake domain for phishing
3	Initial Access	Gaining entry into a system	Sending phishing emails
4	Execution	Running malicious code	Using PowerShell to execute malware
5	Persistence	Staying inside even after reboot	Adding registry keys to auto-start
6	Privilege Escalation	Getting higher privileges	Exploiting a vulnerability to become admin
7	Defense Evasion	Hiding from antivirus or security tools	Disabling Windows Defender
8	Credential Access	Stealing passwords	Dumping LSASS memory
9	Discovery	Learning about the target network	Scanning for shared drives
10	Lateral Movement	Moving to other systems	Using RDP or SMB to access another PC

11	Collection	Gathering important files	Zippping documents or screenshots
12	Command and Control (C2)	Communicating with attacker server	Malware beaconing to remote IP
13	Exfiltration	Stealing data out	Uploading files to attacker's server
14	Impact	Damaging or destroying systems	Encrypting files (ransomware)

2 Techniques — how the attacker does it

Each **tactic** has several **techniques** — specific ways attackers achieve that goal.

Example:

- **Tactic:** *Initial Access*
- **Techniques under it:**
 - **Phishing (T1566)**
 - **Drive-by compromise (T1189)**
 - **Valid Accounts (T1078)**

Each **technique** is given an **ID (T####)** — for example:

- Phishing → T1566
- PowerShell Execution → T1059.001
- Credential Dumping → T1003

3 Sub-techniques — more detail

Techniques can be broken down further into **sub-techniques** (the exact method).

Example:

- **Technique:** Phishing (T1566)
 - **Sub-technique:** Phishing Attachment (T1566.001)
 - **Sub-technique:** Phishing Link (T1566.002)
 - **Sub-technique:** Spearphishing via Service (T1566.003)

Example Attack Mapped to MITRE ATT&CK

Let's walk through a **real-world style attack** step-by-step and map it to MITRE:

Step Attacker Action		MITRE Tactic	Technique (ID)
1	Attacker sends a fake email with a malicious Excel attachment	Initial Access	Phishing (T1566.001)
2	User opens file → macro runs PowerShell script	Execution	Command and Scripting Interpreter (T1059.001)
3	Malware adds itself to startup registry	Persistence	Registry Run Keys (T1547.001)
4	Attacker steals admin password using Mimikatz	Credential Access	OS Credential Dumping (T1003.001)
5	Attacker uses RDP to move to another computer	Lateral Movement	Remote Services (T1021.001)
6	Attacker uploads files to their server	Exfiltration	Exfiltration Over Web Service

(T1567.002)

This helps defenders see **exactly which parts of the attack to detect and block.**

Why MITRE ATT&CK is Important

For Whom	Why it's useful
 Blue Team (Defenders)	Helps build detection rules, incident response, and SIEM alerts.
 Threat Hunters	Maps patterns to known techniques for proactive hunting.
 Red Team / Pen Testers	Plans attack simulations to test real defenses.
 Management / SOC Leads	Shows which attack stages are covered and where gaps exist.

Example of MITRE Use in a SOC

1. Analyst sees suspicious PowerShell command in logs.
 2. They map it to MITRE Technique **T1059.001 (PowerShell)** under **Execution**.
 3. SOC hunts for all systems using that pattern.
 4. They then check if related techniques (like T1547 Persistence) were used — building a full attack chain map.
- This is called “**ATT&CK Mapping**” — it makes incident response faster and standardized.

Variants of MITRE ATT&CK

MITRE has several frameworks for different environments:

Version	Used For
Enterprise ATT&CK	Windows, Linux, macOS networks
Mobile ATT&CK	Android and iOS attacks
ICS ATT&CK	Industrial control systems (e.g., factories, power plants)
ATT&CK for Cloud	Cloud environments (AWS, Azure, GCP)

Summary

Concept	Meaning
MITRE ATT&CK	A global framework describing hacker behavior
Tactics	<i>What</i> attacker wants to achieve
Techniques	<i>How</i> attacker does it
Sub-techniques	More detailed <i>how</i>
Use case	Detection, Threat Hunting, Red Teaming
Goal	Speak a common “language” between defenders and attackers

Quick Example Summary

Phishing email attack example mapped:

1. **Initial Access:** Phishing (T1566.001)

2. Execution: PowerShell (T1059.001)

3. Persistence: Registry Run Keys (T1547.001)

4. Credential Access: Dump LSASS (T1003.001)

5. Exfiltration: Upload data (T1041)

→ These IDs form your **attack chain** and can be visualized in a MITRE matrix.